API Authorization

WSO2 Identity Server allows authorizing user access to an application's API resources based on the application associated roles assigned to the users or user groups. It also allows you to validate the scope of an OAuth access token using XACML policies to provide fine-grained access control to APIs. As the XACML is a deprecated feature, in this section we will discuss **Role Based Access Control**.

In RBAC what happens is, Identity Server validates the user's role assignment (direct or via groups), examines the permissions associated with the roles, and decides whether to permit or restrict the user's access to the API resources.

Register an API resource¶

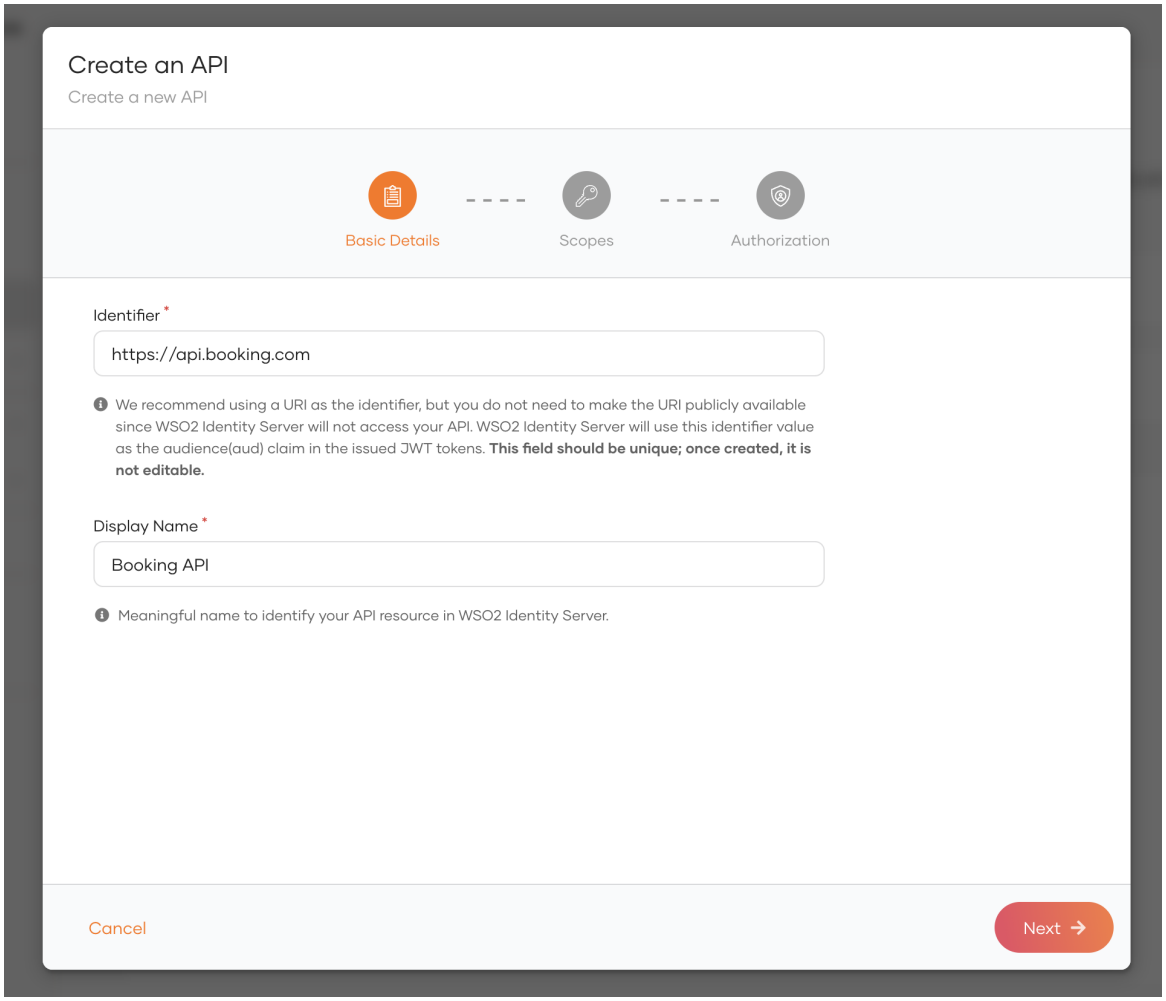
1. Log in to the WSO2 Identity Server Console and go to **Resources > API Resources**.
2. Click **+ New API** to register a new API resource.
3. Enter the following details:

Identifier	This is an identifier for your API resource. This can be any value, but WSO2 Identity Server recommends using the URI of the API resource as the identifier. This value will be used as the aud claim in the issued JWT token.
Display Name	A meaningful name to identify your API resource in WSO2 Identity Server.

Identifier: https://api.booking.com

Display Name: Booking API

CC BY 4.0



4. Click **Next.**
5. Add **Scope** and **Display Name** and click **+ Add Scope.**
6. Add the below two scope

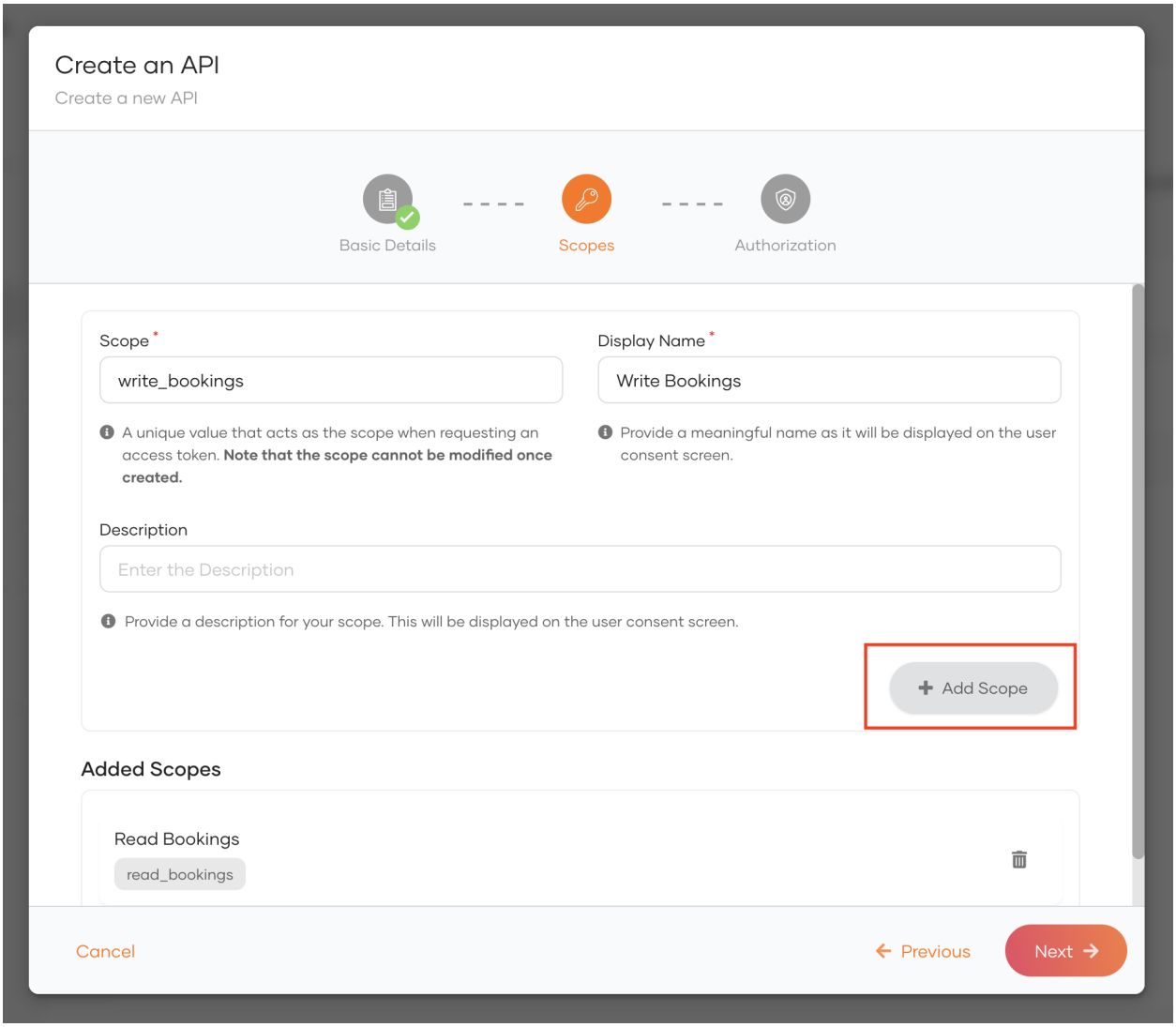
    Scope: read_bookings

    Display Name: Read Bookings

    Scope: write_bookings

    Display Name: Write Bookings

CC BY 4.0



7. Click **Next**.
8. Keep the **Requires Authorization** option checked and Click **Finish**.

CC BY 4.0

Authorize the API resources for an app¶

Once you have registered API resources, you can authorize applications in your organization to access those API resources. This is done by connecting the API resources to the relevant applications.

Follow the below steps to authorize the API resource for an app.

1. Use the sample app created in **6. Identity Federation** tutorial.

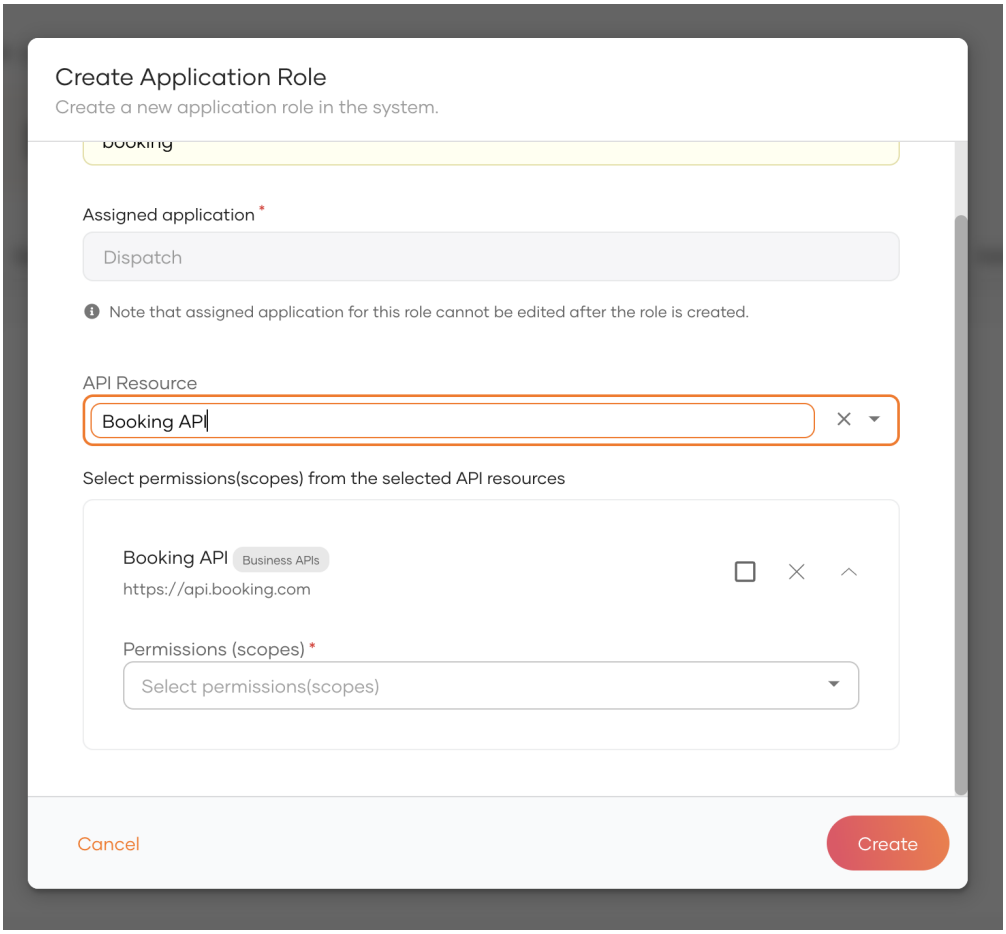
> **Warning**
>
> Note that you cannot authorize API resources for a SAML application.

2. Enable login consent.
    a. View the created application and Goto **Advanced** tab.
    b. Uncheck **Skip login consent**.
    c. Click **Update**.
3. View the created application and goto **Authorization tab**.
4. Click **Authorize resource**.
5. From the Resource list select Booking API.
6. For Authorized Scopes, select both scopes, **Read Bookings** and **Write Bookings**.
7. For the **Authorization Policy** since you have checked **Requires Authorization** scope while registering the API Resource, RBAC will be selected by default.
8. Click **Finish**.

CC BY 4.0

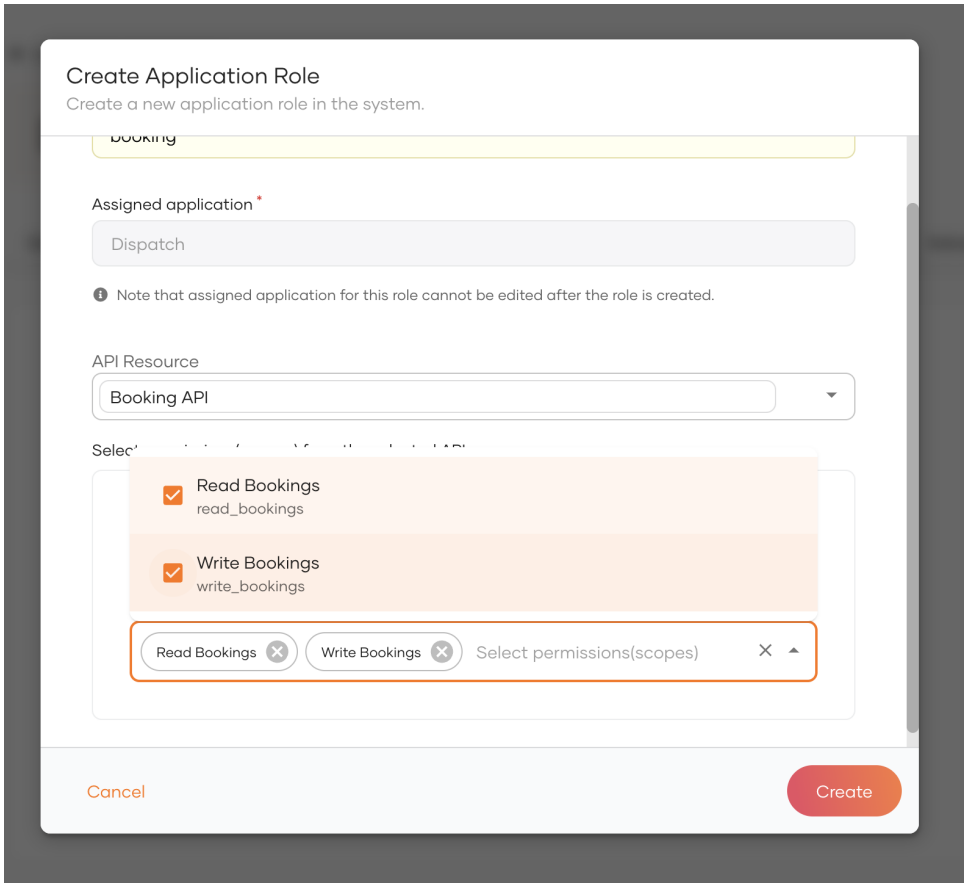
Associate roles to the application

1. Create an Application Role and assign the scopes of the registered resources.
2. Go to select the Application **Dispatch**.
3. Goto **Roles** tab.
4. Clear any existing roles added.
5. Select Role Audience as Application and click on **+ New Role**.
6. Add **booking** as the role name.
7. As the API Resource, select **Booking API**.



8. Select **read_bookings** and **write_bookings** as permissions (scopes).

CC BY 4.0



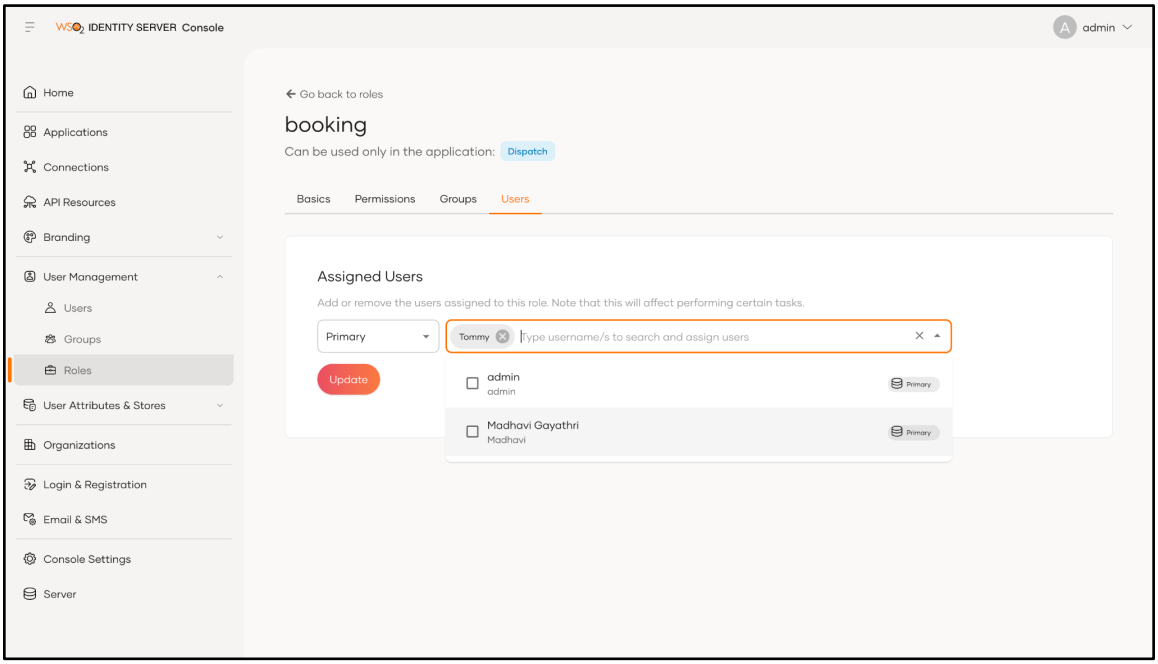
9. Click **Update**.

CC BY 4.0

Assign users or groups to roles

Assign the created booking application role to the already created user Tommy.

1. On the WSO2 Identity Server Console, expand the **User Management** menu item and select **Roles**.
2. From the list of roles, select **booking**, application role.
3. Goto the **Users** tab.
4. Click on **Assign Users**.
5. Click on **Type username** area.
6. From the list of users select **tommy** and click **Update**.



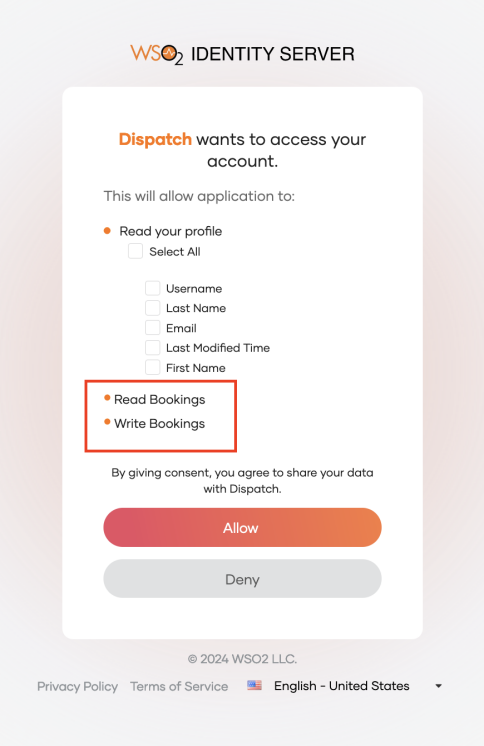
CC BY 4.0

Request registered resource from the client app end

1. Open `<TOMCAT_HOME>/webapps/pickup-dispatch/WEB-INF/classes/dispatch.properties`.
2. Append **read_bookings** and **write_bookings** to the value of the **scope** property, separated by spaces. For example: scope=openid email profile internal_application_mgt_view read_bookings write_bookings
3. Save the file. Restart Tomcat: in `<TOMCAT_HOME>/bin` run `catalina.bat stop` and then `catalina.bat start` on Windows, or `sh catalina.sh stop` and then `sh catalina.sh start` on Linux and macOS.

Try it

1. Access the link http://localhost:8080/pickup-dispatch/oauth2client
2. and click on the **LOGIN** button.
3. Add the credentials of **Tommy** user and sign in.
4. You will be prompted to give permission to the below scopes.



CC BY 4.0

5. Click **Allow**.
6. By consenting to the scopes you will be granting access to the client application to use the API resources associated with it.

CC BY 4.0